

SECAUDIT 057 - SNAP SLAPPER Windows beta

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Audit ID	SECAUDIT 057
Date	2026-09-16
Scope	Completed Windows beta source, .slapper project loading, image layers, publishing handoff, frozen onedir package, and installed copy at C:\snapsmack\slapper. Linux is outside this beta audit.
Method	Manual trust-boundary review, hostile-input regressions, vendor-advisory review, dependency audit, source and frozen-application tests, package inventory/hash verification, Authenticode inspection, and installed ACL inspection. No exploit code.
Status	CLOSED FOR LOCAL BETA (2026-09-18). All application-code findings closed; the installed folder is protected and 366/366 files hash-verified. F5's remaining line - a Microsoft-recognised Authenticode certificate - is DROPPED , owner decision (Sean, 2026-09-18): "that is not ever happening." Releases carry SnapSmack's own Ed25519 signature; SmartScreen's first-run warning is a documented consequence.
Related	SECAUDIT 056 high-bit / RAW release audit.

Summary

The completed Windows beta has been rebuilt, installed, and tested after a new security pass. The pass closed project-validation ordering, external-file consent, archive ambiguity, temporary-file cleanup, publishing response/redirect handling, and unsafe result-link handling.

The installed build deliberately does not support SVG. Qt's 2026 advisory identifies Qt SVG versions from 6.9.0 through 6.11.0 as affected by CVE-2026-6210. An attempted upgrade to PySide6/Qt 6.11.2 passed source tests but produced a frozen application that could not reliably load QtCore on this Windows host. The safer beta decision was therefore to refuse SVG before parsing and remove the Qt SVG libraries/plugins from the package entirely. The installed tree contains none of Qt6Svg.dll, QtSvg.pyd, qsvg.dll, or qsvgicon.dll. Vendor advisory: <<https://www.qt.io/blog/security-advisory-type-confusion-and-heap-buffer-overflow-vulnerability-in-qt-svg-marker-handling>>.

Findings

F1 - HIGH - Qt SVG parser exposure

Finding: The pinned Qt 6.9.3 line is covered by CVE-2026-6210 when Qt SVG is present and reachable.

Remediation: SVG was removed from the file picker and supported layer contract; the engine refuses .svg before invoking an image library; Qt SVG hidden imports and packaged DLL/plugins were removed. Help text now directs users to convert SVG to PNG.

Verification: Source regression proves SVG refusal. Candidate and installed recursive inventories contain zero Qt SVG runtime files.

Status: **CLOSED for this beta.** The vulnerable component is neither shipped nor accepted as input.

F2 - HIGH - Project validation and external local-file access

Finding: A project could reach embedded-source extraction or image decoding before every layer/history collection was validated. Image-layer and font paths also needed the same explicit external-file approval as the main source.

Remediation: Complete project collection validation now precedes extraction, filesystem access, and decoding. Imported projects collect all external source, image-layer, and font paths and require one explicit confirmation before access. Layer path and asset_ref types and lengths are validated.

Verification: Hostile-project regressions prove malformed layers cannot invoke embedded extraction and external layer paths raise the approval boundary before access.

Status: CLOSED.

F3 - MEDIUM - Ambiguous archives and temporary source retention

Finding: Case-insensitive duplicate ZIP member names could make archive interpretation ambiguous. Portable-project extracted originals could remain in the temporary directory until process exit.

Remediation: Project archives reject duplicate member names case-insensitively. Extracted portable originals are registered for deterministic finalizer cleanup.

Verification: Duplicate-member rejection and temporary-original cleanup regressions pass.

Status: CLOSED.

F4 - MEDIUM - Publishing response and link trust

Finding: Publishing replies lacked a strict response ceiling; redirects could change HTTPS port; returned links could use unsafe local/custom schemes and remain launchable.

Remediation: Responses are capped at 2 MiB. Redirects must remain on the exact HTTPS host and port. Returned links are limited to http/https, and the View action is disabled when no safe public URL exists.

Verification: Cross-port redirect, oversized-response, unsafe-scheme, and email-contract regressions pass.

Status: CLOSED.

F5 - HIGH - Installed package integrity and Windows publisher identity

Finding: The previous install inherited `Authenticated Users: Modify`, unsafe for an onedir application that loads adjacent libraries. The executable also has no Authenticode publisher signature.

Remediation: The installed folder now grants Full Control only to Administrators and SYSTEM and Read/Execute to Users. Its generated dependency manifest was verified read-only against every installed payload file.

Verification: Installed inventory: 366 listed files, 366 actual files, zero hash/size failures, zero missing files, zero extras. Installed ACL has no ordinary-user write grant. Candidate and installed executable SHA-256 match.

Status: CLOSED. The writable-install issue is closed. Authenticode remains NotSigned and will stay that way - no certificate will be bought (owner decision, 2026-09-18). Publisher identity = SnapSmack's own Ed25519 release signature, verified by the updater and SMACKBACK.

Verification record

- Core source suite: **94 passed; 52 subtests passed.**
- Qt/UI suite: **90 passed.**
- Focused security suite: **43 passed.**
- Python dependency audit: **no known vulnerabilities** in the resolved requirements at audit time.
- Candidate distribution audit: **passed, 366 files.**
- Installed distribution manifest: **366/366 files matched exactly.**

- Installed editing gate: **passed** - cold start 2077.187 ms, 19.886 displayed updates/second, maximum first response 94.861 ms, exact preview/reference error 0.0.
- Installed real-image/edit/PSD QA: **passed**.
- Candidate and installed executable SHA-256:
FD8F36C6D56F787D029448AA609DCC0EADB3ABD7479A7D6DD325B4329726DEE1.
- Authenticode: **NotSigned**.
- Installed Qt SVG runtime count: **0**.
- OpenImageIO advisories reviewed: <<https://github.com/AcademySoftwareFoundation/OpenImageIO/security>>.

Residual risk and release decision

The native image-decoder worker is bounded by a Windows Job Object for memory, duration, and descendant lifetime, but it is not an AppContainer or restricted-token sandbox. RawTherapee is an external, locally installed tool whose publisher/hash trust still depends on the local installation. These are documented residual risks for the local beta, not newly discovered regressions.

The Windows beta is cleared for local use in its protected installed directory. Public release is not gated on Authenticode (owner decision, 2026-09-18 - no certificate will be purchased); it is gated on the SnapSmack-signed installer/update trust path being verified end to end. Linux remains deferred to the full release as requested.

Platform dependency note

The remaining signing blocker is not a defect in SNAP SLAPPER. It reflects a Windows distribution ecosystem in which independent developers are pressured to purchase and continually renew third-party credentials merely to prevent their software from being treated as presumptively untrustworthy. Microsoft presents this as a security boundary, but the practical effect is centralized gatekeeping and recurring rent extraction from small publishers. We strongly object to that arrangement and would prefer an open, durable, non-rent-seeking method for establishing publisher identity.